SHOPMATE AI

Mobile e-commerce with a safe AI assistant

Fil Rouge — Mobile Augmented AI

Omar Fahid | Defense preparation | 24 October 2026

Customer chat

Live stock and price

COD order with confirmation

The store needs fast answers without losing control

A COD store handles repetitive questions and sensitive actions every day.

Customers

Ask about products, delivery, returns and their orders.

Store manager

Updates catalogue data and needs a trace of agent activity.

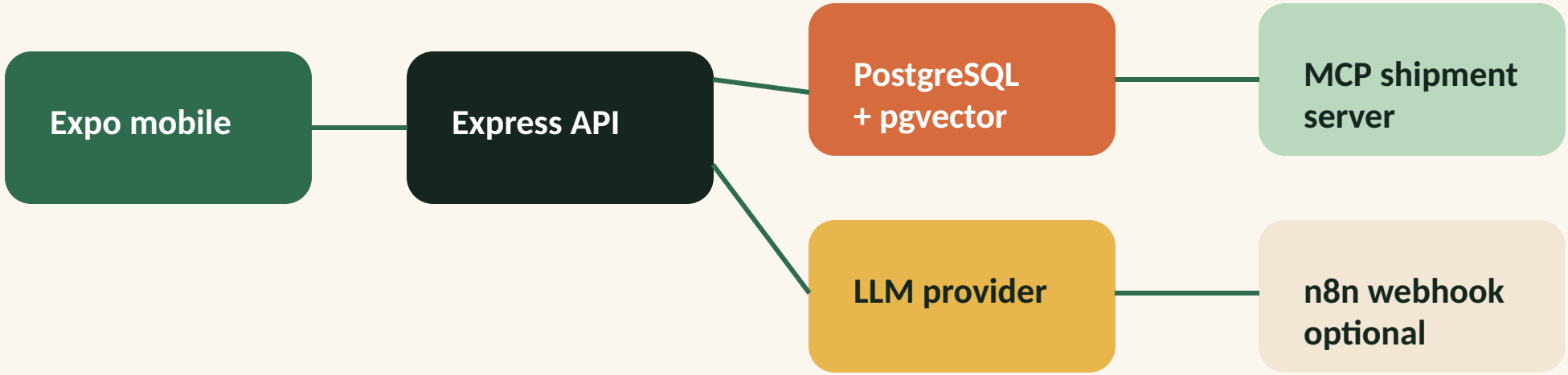
Risk

An AI must not invent prices, create orders by mistake or expose another store.

One application for customers and store managers

The mobile app connects each request to a controlled backend. The backend decides which source can answer it.

A controlled path from a message to verified data



JWT provides user and store context. The server ignores any storeId sent by the client.

RAG answers knowledge questions. Tools read or act on live data

RAG: store knowledge

- Searches uploaded delivery and return documents
- Uses chunks filtered by storeId
- Cites sources or says: « Je n'ai pas cette information »

Function calling: live operations

- Reads current product, stock and price from PostgreSQL
- Creates or cancels an order only after confirmation
- Uses Zod validation and an eight-tool allowlist

The assistant can answer only within the store rules

No hallucination	Similarity threshold blocks unsupported RAG answers.
Prompt injection	Documents and tool results stay data, never instructions.
Sensitive requests	Discounts, refunds, medical, legal and off-topic requests are refused and can go to the manager.
Safe writes	Orders require explicit confirmation and run inside a transaction.
Tenant isolation	The JWT storeId scopes queries. Customers see only their own orders.

Automated checks cover the critical backend paths

Current local evidence

Auth	refresh rotation and logout
Tenant isolation	store and customer boundaries
Orders	stock consistency and explicit confirmation
Agent	Zod allowlist, guardrails and cost limits
Automation	n8n notification service

Run from backend

npm test

CI also runs this command on GitHub Actions.

The clean-clone, phone and public-deployment checks still need rehearsal evidence.

A 6–8 minute story with a working fallback

01

Customer chat

RAG answer with source, then live stock.

02

COD order

Show the confirmation before the write.

03

Admin work

Change catalogue, upload a document and inspect chunks.

04

Audit

Open the full trace: question, tools, sources, tokens and latency.

Fallback: a recorded video shows the same journey if the network, phone, LLM or MCP server fails during the defense.

ShopMate AI

A store assistant that knows where its answer comes from

Ready for the demo.

24 Oct 2026

Key defense points

- RAG uses store documents and cites them
- Tools read live data and protect writes with confirmation
- JWT store context protects tenant data
- Audit logs make every agent turn reviewable